LAB ASSIGNMENT REPORT

Course: Web Security & Penetration Testing | Assignment: DAY54-TLS-AND-PKI

Q1-Q3 - HANDSHAKE, CERTIFICATE CONTENTS, CHAIN OF TRUST

DAY 54

Jiwosh Shrestha

(9 MARKS)

Q1 - Handshake [3]

TLS 1.3 handshake (simplified): (1) ClientHello - client sends supported versions, cipher suites, key-share (ephemeral DH public value), and extensions (SNI, ALPN, etc.). (2) ServerHello - server selects version and suite, sends its key-share. (3) Server parameters & certificate - server sends encrypted extensions, its certificate chain, and a CertificateVerify signature proving possession of the private key. (4) Client authenticates the certificate chain, derives handshake/application traffic secrets from the shared DH secret, and sends Finished. (5) Server Finished - both sides can now send application data. Each side contributes an ephemeral key-share (forward secrecy); the server contributes its certificate and signature (authentication); both contribute Finished MACs that bind the handshake transcript.

Q2 - Certificate contents [3]

Fields that matter for validation: subject / Subject Alternative Name (SAN) - names the certificate is valid for; issuer - who signed it; validity period (notBefore / notAfter); public key and algorithm; signature algorithm and signature value; basic constraints / key usage / extended key usage - whether it is a CA and for what purposes it may be used; authority/subject key identifiers for chain building. SAN replaced CN because the Common Name field was ambiguous (could hold a directory name or a hostname) and browsers historically disagreed on parsing. The SAN extension provides an explicit, multi-value list of DNS names and IP addresses; modern clients ignore CN when SAN is present (RFC 6125 / CA-Browser Forum baseline).

Q3 - Chain of trust [3]

A client builds a chain by starting at the leaf (server) certificate and walking issuer links until it reaches a trust anchor (root CA) in the client's trust store. Each link is checked: signature valid under the parent's public key, validity period, basic constraints (CA:true for intermediates), key usage, and path-length constraints. If an intermediate is missing, the chain is incomplete and validation fails - the client cannot bridge from leaf to a trusted root. Servers must send the full chain (leaf + intermediates); clients generally do not fetch missing intermediates automatically in a security-sensitive way.

LAB ASSIGNMENT REPORT

Course: Web Security & Penetration Testing | Day 54
Validation, Versions & Operations
Q4-Q6 - VALIDATION, VERSIONS AND SUITES, OPERATIONS

DAY 54
Jiwosh Shrestha
(9 MARKS)

Q4 - Validation [3]

Client checks include: (1) chain builds to a trusted root; (2) signatures and validity periods along the chain; (3) hostname matches SAN (or legacy CN); (4) certificate not revoked (OCSP/CRL/OCSP stapling where used); (5) key usage / EKU appropriate for server authentication; (6) no known-weak algorithms. Disabling verification (e.g. verify=False, InsecureSkipVerify) removes authentication of the server: any attacker who can terminate TLS can present an arbitrary certificate and read or modify traffic. It converts TLS into an encrypted but unauthenticated channel - suitable only for controlled lab use, never production.

Q5 - Versions and suites [3]

TLS 1.2: supports many legacy suites including RSA key transport (no forward secrecy) and CBC modes; handshake is cleartext until ChangeCipherSpec; more round trips. TLS 1.3: removes RSA key transport and static DH; mandates ECDHE (or DHE) for forward secrecy; only AEAD ciphers (GCM, ChaCha20-Poly1305, CCM); encrypts more of the handshake; fewer round trips (1-RTT, 0-RTT option). CBC suites are discouraged because TLS-CBC historically suffered padding-oracle and timing attacks (BEAST, Lucky Thirteen). AEAD modes avoid these classes of bugs by design and are required in TLS 1.3.

Q6 - Operations [3]

Key protection: private keys stored in HSM/KMS or filesystem with strict permissions; never in source control; access audited. Renewal automation: use ACME (e.g. Let's Encrypt) or enterprise RA workflows so certificates renew before expiry without manual intervention. Expiry monitoring: alert on certificates nearing notAfter (e.g. 30/14/7 days); inventory all public-facing endpoints. CT monitoring: Certificate Transparency logs record issued certificates; monitor for unexpected certificates for your domains (possible mis-issuance or shadow IT).

LAB ASSIGNMENT REPORT

Course: Web Security & Penetration Testing | Day 54
Failure Analysis
Q7 - FAILURE ANALYSIS

DAY 54
Jiwosh Shrestha
(2 MARKS)

Q7 - Failure analysis [2]

Three common TLS incidents and fixes: (1) Expired certificate - browsers show a fatal warning; clients refuse the connection. Fix: renew and deploy the new certificate (and chain) before notAfter; enable automated renewal and expiry alerts. (2) Incomplete chain (missing intermediate) - some clients fail validation while others succeed if they have the intermediate cached. Fix: configure the server to send leaf + intermediates; verify with openssl s_client -showcerts or SSL Labs. (3) Hostname mismatch (certificate issued for the wrong name/missing SAN) - client rejects the certificate. Fix: re-issue with correct SAN entries covering all intended hostnames; avoid relying on CN alone.

Key takeaways

- TLS 1.3: ECDHE + AEAD only, forward secrecy by default, never disable certificate verification in production.
- SAN is authoritative for hostname checks; send the full chain; monitor expiry and CT logs.
- Common failures: expired cert, missing intermediate, hostname mismatch - all preventable with automation.
- Private keys stay in HSM/KMS; no real credentials in this submission.